

寻找更好的散列函数

Susan Landau

在理论应用到现实世界的时候,我们经常听说数学的超乎寻常的效力,这些应用既令人欣喜又是意想不到的.从互联网上我们已经发现数论在公钥密码学方面的应用(Diffie-Hellman 系统, RSA 算法, 椭圆曲线密码系统),以及图论在网络设计方面的利用.现行互联网数据的安全,使目前我们面临着相反的境遇:寻找数学理论的问题.这个问题就是散列(hash)函数.

散列函数是一个容易计算的压缩函数,它把可变长度的输入转化成固定长度的输出.我们感兴趣的一类散列函数,被称作密码散列函数,它是“单向”函数,也就是说正向很容易计算,反向(逆)运算很难或者计算的代价非常高.¹⁾散列函数被用作一组长数据的压缩表示——一个数字指纹——并提供数据完整性.散列函数提供数据完整性的方法是,在初始时刻 t_0 计算的一个特殊数据块的散列值是 h_0 ,当在此后的时刻 t_1 这个数据需要用时,再次计算散列值 h_1 .如果这两个散列值 h_0 和 h_1 相等,那么这块数据不曾被变动(从而被证实是完整的——译注).公钥密码学的共同发明者之一 Ralph Merkle 称散列函数为密码学的“输送带”(duct tape).在其它方面,散列函数被用于确定软件的完整性、数字签名、信息鉴别,并且用作一次性口令;它们也被用于许多互联网协议,包括 SSL/TLS,能确保 Web 传输安全的传输层协议、IPsec 以及 SSH.²⁾

因为散列函数“缩短”了数据,散列值之间的碰撞(即不同的输入给出相同输出——译注)是不可避免的.一个密码学散列函数必须满足 3 个基本性质:1. 抗原象(有时称不可逆性):“对特定的输出,找到一个输入,使得它的散列值等于这个输出”在计算上是不可行的.2. 抗第二原象:“对特定的输入,找到与它有同样输出的第 2 个输入”在计算上是不可行的.3. 抗碰撞:“找到两个不同的输入,使它们的输出是同一个值”在计算上是不可行的.由于“生日”悖论这一著名的结果:在(任意)23 人中,有两个人具有相同生日的概率大于 $1/2$,Merkle [10, p.12–13] 和 Gideon Yuval [12] 在 1979 年分别独立地观察到——找到一个碰撞平均仅需要搜索原来要搜索的空间的平方根就可以了.因而 n 比特的散列

译自: Notices of the AMS, Vol.53 (2006), No.3, p.330–332, Find Me a Hash, Susan Landau. Copyright ©2006 the American Mathematical Society. Reprinted with permission. All rights reserved. 美国数学会与作者授予译文出版许可.

- 1) 根据应用,散列函数可以是“有密钥的”,也可以是“没有密钥的”.在这里我们忽略这一区别,尽管我们注意到包括信息鉴别码(Message Authentication Code, 缩写为 MAC)在内的有密钥的散列函数,其理论已被充分理解.——原注
- 2) SSL,由 Netscape Communications Corporation 开发的协议,用于确保互联网通信的安全与隐私,为 the Secure Sockets Layer (安全套接层)的缩写;TLS,一种用于在互联网中提供安全网络通信的标准协议,为 the Transport Layer Security (运输层安全)的缩写;IPsec, the Internet Protocol Security (互联网安全协议)的缩写,用于保证在 IP (互联网协议)层数据交换的安全;SSH, the Secure Shell 的缩写,是建立在应用层和运输层基础上的安全协议.——校注

函数至多是 $n/2$ 比特抗碰撞攻击安全的。

散列函数的一个常用设计方法是迭代: 使用一些被结合在一起的运算的一个小集合, 这个小集合被称为轮 (round). 这样, 算法就用指令的一个小集合组成, 这是实现的一个重要方面 (同样的设计范式对分组密码也是一样的). Merkle 和 Damgård 独立地给出了如何构造一个抗碰撞压缩函数, 并对其迭代产生一个抗碰撞散列函数的方法 [11], [2]. 被称作 “Merkle-Damgård 构造” 的思想具体描述如下: 设抗碰撞压缩函数 f 把 $n+m$ 比特映射成 n 比特. 把输入 I 分成长度为 n 的 k 个块: $x_1, x_2, \dots, x_k$, 如果必要 (即当 $n(k-1) < b < nk$ 时, 这里 b 为 I 的长度.——校注), 将最后一块用 0 填满. 以被称为初始向量 IV 的 n 比特随机串开始. 设 b 为 I 的长度, 定义另外的块 x_{k+1} , 其右部为 b 的二进制展开 (假设 $b < 2^n$), 左部用 0 填满. 则散列函数 h 定义为:

$$\begin{aligned}h(x) &= H_{k+1}, \\H_0 &= IV, \\H_i &= f(H_{i-1} || x_i), \quad 1 \leq i \leq k+1.\end{aligned}$$

这里 $||$ 表示连接.

h 的任何碰撞意味着 f 在某个状态 i 发生碰撞, 由此观察得到 h 是抗碰撞的.

大多数流行的散列函数以 Merkle-Damgård 构造作为基础. 6 年前, 有几个流行的密码学散列函数, 包括 MD5 和 SHA-1. 由 Ron Rivest 开发的 MD5, 是 Rivest 早期的一个散列函数 MD4 的强化形式, 是一个 128 比特散列函数. 由于 “生日悖论” 的攻击, MD5 只能是 64 比特强的; 这一安全长度较短的散列函数被提供给美国国家标准和技术研究所 (NIST) 裁定, 但 MD5 未能成为美国联邦信息处理标准 (FIPS). FIPS 认证意味着该系统被批准卖给联邦政府, 而对于计算机产业来说联邦政府是一个重要市场. NIST 认可 SHA-0 作为联邦信息处理标准 (SHA-0 就是原始的 SHA. SHA 为 the Secure Hash Algorithm (安全散列算法) 的缩写). 该算法由美国国家安全局 (NSA) 也是在 MD4 的基础上开发的; 它是一个 160 比特的散列算法, 主要用于 Skipjack——密钥长度为 80 比特的分组密码, 是快捷系统 (the Clipper system) 的一部分. 2 年之后 NSA 提供了 SHA-1, 它也成为了一个 FIPS, 其算法不同于 SHA-0 之处是利用了一个轮函数的循环移位运算. SHA-0 之后不久 SHA-1 的快速发展使得用户避开了早期的算法 SHA-0, 事实上, SHA-0 的弱点被发现——但是 MD5 和 SHA-1 已经被广泛地使用 (尽管 MD5 不是 FIPS, 但仍被用于许多协议). 因此我们有了麻烦.

MD5 在 1993 年已经陷入困境, 那时 Bert den Boer 和 Antoon Bosselaers 发现它的压缩函数有问题 [3]; 3 年之后更多的问题被 Hans Dobbertin [4] 发现. 情况在 2004 年变得更糟, 在加利福尼亚的圣巴巴拉召开的一次密码学会议上, 王小云、冯登国、赖学嘉和于红波展示的关于 MD5 碰撞攻击的工作受到了热烈欢迎 (这类攻击也适用于其它几个散列函数: HAVAL, MD4, 和 RIPEMD) [13]. MD5 已现颓势, 但这是最后一击. 在这个会议上, Eli Biham 和 Rafi Chen [1] 展示了如何找到 SHA-0 “接近” 的碰撞, Antoine Joux 给出了一个对 SHA-0 的实际的碰撞攻击 [5]. SHA-1 好像仍然是安全的.

2005 年, 情况变得更糟, 王与她的合作者尹依群 (Yiqun Lisa Yin) 及于红波给出了对 SHA-1 的需要 2^{69} 步 (代替了原来预期的 2^{80}) 的一个碰撞攻击 [14]; 后来, 王、姚期智和姚储枫又给出了对 SHA-1 的仅需要 2^{63} 步的一个碰撞攻击 [15]. 有一个好消息是, 这些攻击不是一个第二原象攻击, 而且也不意味着所有用 SHA-1 的协议对于完整性不安全 (如, 在 SSL3.0/TLS 协议的协调中使用 SHA-1 并不受这些攻击的影响). 但是, 这些攻击也的确说明必须尽快更换 SHA-1, 在新的应用不能再使用它. 但如何进行却是既明确又不明确.

准备就绪的 SHA-256 同样也是由 NSA 开发的, 并且已经是一个 FIPS 了 (SHA-384 和 SHA-512 同样是 FIPS). SHA-256 比 SHA-1 慢 3~4 倍, 但这不是真正的问题. 推动一个新的算法进入密码基础设施, 无论是 SHA-256 或是 SHA-1 的直接替代 (包括已完成的 RIPEMD-160, 输出缩短到 160 比特的 SHA-256, 以及打了“补丁”的 SHA-1) 都不是一个容易的任务. 虽然计算机制造商认识到替代 SHA-1 的重要性, 并且 SHA-256 被微软公司、太阳微系统公司和其它制造商安排在下一代操作系统, 但是 SHA-1 和 MD5 仍然在将来几年中会留在遗留的系统中. 同时, SHA-256 也可能兼有 SHA-1 的一些结构, 并因此可能易于遭到攻击, 在 256 比特的长度上, 这个算法足够大且足够强, 能满足目前的需要. 这是向前发展的清晰步骤.

不清楚接下来会发生的事情. 10 年之前, 需要替代数据加密标准 (the Data Encryption Standard, 缩写为 DES), 因为自上世纪 70 年代以来, 密钥长度为 56 比特的加密算法已经发挥了作用 (如, [6], [7]). 幸运的是, 自上世纪 80 年代以来越来越多的基础研究投入到分组密码设计, 这些设计大部分都对 DES 攻击的想法中受益. 在 2002 年被批准为 FIPS 的高级加密标准 (the Advanced Encryption Standard, 缩写为 AES), 其强度也是基于这一研究 [8]. 很明显, 我们需要新的散列函数, 但目前散列的研究所处的地位不同于 10 年前分组的密码研究所处的地位. 在我们真正地理解安全散列函数的基础之前,¹⁾ 让 NIST 开始认真地竞选下一个散列函数是没有意义的. DES, 一个展现对于分组结构密码安全性理解得很好的算法, 给密码专家提供了练习. 同样, SHA-256 很可能是开始研究安全散列函数的恰当的地方. 散列函数的理论是什么? 数学家们并不是很经常被问及为“输送带”发展一套理论, 但是很显然密码学散列函数目前急需做这样的工作.

参考文献 (略)

(李广飞 赵振江 译 陆柱家 校)

1) 存在基于困难的数学问题的散列函数, 它们看起来似乎是安全的, 但这些散列函数效率低, 而且在现实中没有应用.——原注